

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA51 **COURSE NAME:** Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Comparative Analysis

Code of Conduct:

I Thanveer T(192424107) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:



Annexure A

Comparative Analysis

1. Apply **SSL/TLS and IPsec protocols** to a secure communication scenario and determine which provides better security for web-based and network-layer protection.
2. Design a secure email system by comparing **end-to-end encryption and gateway-based encryption**, and justify the most suitable approach for enterprise use.
3. Apply **HMAC and Digital Signature techniques** to a data transmission scenario and analyze which method provides better authentication and integrity.
4. Create a **spam detection system** by comparing supervised learning and unsupervised learning approaches, and evaluate their effectiveness in real-world email filtering.
5. Design a secure communication framework by comparing **AES and RSA encryption techniques**, and determine their roles in achieving confidentiality and efficiency.

Answers to Comparative Analysis Questions

Each question below is addressed through a defined real-world scenario, followed by a structured, multi-parameter comparison, a set of key observations drawn from that comparison, and a critical justification that recommends a course of action. Wherever applicable, the discussion is grounded in the relevant IETF/NIST standards that govern the mechanisms under review.

Question 1 — SSL/TLS vs IPsec for Secure Communication

Scenario

A regional bank operates a customer-facing internet banking portal that must be reached securely by browsers over the public internet, and it also maintains a private WAN link between its head office and five branch offices that must carry all traffic — banking application data, VoIP, and file transfers — without modifying every individual application. The security team must decide where SSL/TLS should be applied and where IPsec is the more appropriate control.

Table 1.1 — SSL/TLS and IPsec compared across implementation and security parameters

Parameter	SSL/TLS	IPsec
OSI layer of operation	Transport / Session layer (between TCP and the application)	Network layer (operates directly on IP packets)
Scope of protection	Secures a single application session, e.g. one HTTPS connection	Secures every packet between two hosts or gateways, application-agnostic
Application awareness	Application must be TLS-aware (browser, mail client, etc.)	Fully transparent to applications; no code changes required

Authentication basis	X.509 server certificates (optionally mutual-TLS for clients)	Pre-shared keys or certificates via IKE (Internet Key Exchange)
Typical deployment	Public web services, REST APIs, customer portals	Site-to-site VPNs, remote-access VPNs, internal backbone links
NAT traversal	Works natively, since it rides over ordinary TCP	Requires NAT-Traversal (NAT-T) extensions, especially in ESP mode
Granularity of control	Per-session / per-port; easy to selectively enable per service	Per-tunnel; typically protects all traffic between two endpoints
Governing standard	RFC 8446 (TLS 1.3)	RFC 4301 (IPsec Architecture), RFC 4303 (ESP)

Key Observations

- **Scope of protection:** SSL/TLS protects data only for the application that explicitly opens a TLS session, whereas IPsec protects the IP layer itself, so every application riding on top inherits the protection automatically.
- **Protocol independence:** Because IPsec operates below the transport layer, it is the only realistic option for securing non-HTTP traffic such as VoIP and file-sharing protocols between the branch offices.
- **End-user trust signalling:** TLS certificate validation gives the browser a direct, human-verifiable trust indicator (the padlock icon), which IPsec cannot offer to an end user.
- **Deployment overhead:** IPsec tunnels require coordinated configuration on gateway devices at both ends, while TLS requires only a certificate on the server — making TLS far easier to roll out for public-facing services.

Critical Analysis and Recommendation

For the internet banking portal, SSL/TLS is the better fit: customers connect from unmanaged devices with an ordinary browser, and TLS gives per-session encryption, certificate-based server authentication, and forward secrecy in TLS 1.3 without requiring any client-side configuration. For the branch-to-branch WAN, IPsec is the stronger choice because it protects every packet leaving the gateway — including protocols with no built-in encryption — and it centralises key management at the router/firewall rather than at every individual application.

Recommendation: deploy TLS 1.3 for the customer portal (web-based protection) and a site-to-site IPsec tunnel using IKEv2 with AES-256/SHA-256 for the branch WAN (network-layer protection). The two protocols are complementary rather than competing, and a defence-in-depth posture uses both simultaneously.

Question 2 — End-to-End vs Gateway-Based Email Encryption

Scenario

A 3,000-employee manufacturing enterprise is redesigning its email security architecture. Legal and finance teams exchange highly sensitive contracts and must be certain that no intermediate party can read message content. At the same time, the IT security team is contractually required to run antivirus scanning and data-loss-prevention (DLP) checks on all outbound mail, and compliance officers must be able to archive and, where lawfully required, review correspondence. The design question is whether to adopt end-to-end encryption, gateway-based encryption, or a combination of the two.

Table 2.1 — End-to-end and gateway-based email encryption compared

Parameter	End-to-End Encryption (PGP / S/MIME)	Gateway-Based Encryption
Point of encryption	Sender's device; decrypted only on recipient's device	Organisation's email gateway/server, often over TLS to the next hop
Key management	Each user holds a personal key pair; burden is on the user	Centrally managed by IT at the gateway
Content visibility in transit	Opaque to every intermediate server, including the sender's own gateway	Gateway can decrypt and inspect content before re-encrypting/forwarding
Antivirus / DLP scanning	Not possible on message body without breaking confidentiality	Fully supported, since the gateway can inspect plaintext
Regulatory archiving/eDiscovery	Difficult — organisation may not hold the decryption key	Straightforward — organisation controls the gateway
User experience	Requires certificate/key exchange with every external contact	Transparent to end users; no client configuration
Best suited for	Highly sensitive, targeted correspondence (legal, executive)	Bulk day-to-day business correspondence
Relevant standard	RFC 4880 (OpenPGP), RFC 8551 (S/MIME 4.0)	RFC 3207 (SMTP over TLS / STARTTLS)

Key Observations

- **The same property that maximises confidentiality also blocks security scanning:** Because the message is opaque to every intermediate hop, malware scanning, spam filtering, and DLP keyword inspection cannot be performed on the body without the recipient's private key.
- **Key custody is the central risk:** A single lost or unrecoverable private key can permanently lock the organisation out of its own archived correspondence — a serious concern for compliance retention.

- **Usability drives adoption:** Gateway-based encryption keeps the security burden on IT rather than end users, which historically produces far higher adoption rates than PGP/S-MIME, which are notorious for low voluntary uptake.
- **No single model is complete:** Neither approach alone satisfies every requirement in this scenario; PGP/S-MIME satisfies confidentiality but not compliance scanning, and gateway encryption satisfies compliance but weakens confidentiality against a compromised gateway.

Critical Analysis and Recommendation

Gateway-based encryption should form the default layer for the enterprise, since it lets the security team keep antivirus and DLP scanning active on essentially all traffic and gives IT a single point of key management for thousands of mailboxes. However, for the legal and finance correspondence identified as highly sensitive, gateway-only encryption is insufficient, since a compromised gateway or a malicious insider could expose contract terms before a deal closes.

Recommendation: adopt a layered model — gateway-based TLS/DLP scanning as the enterprise-wide baseline, with S/MIME end-to-end encryption reserved for a defined list of high-sensitivity users and distribution lists (legal, M&A, executive leadership). This hybrid approach is the most suitable for enterprise use because it balances confidentiality against the equally real requirements of malware defence and regulatory compliance.

Question 3 — HMAC vs Digital Signatures for Data Transmission

Scenario

Two data centres of a payment-processing company exchange end-of-day settlement files containing transaction totals owed between them. The receiving data centre must be able to prove, if a dispute later arises, that a specific file was produced by the sending data centre and was not altered in transit. The security architect must choose between HMAC and digital signatures — or determine where each is appropriate.

Table 3.1 — HMAC and digital signatures compared for authentication and integrity

Parameter	HMAC	Digital Signature
Underlying primitive	Keyed hash function (e.g. HMAC-SHA256)	Hash function + asymmetric key encryption (e.g. RSA, ECDSA)
Key type	Single symmetric secret, shared by both parties	Sender's private key (signing) and public key (verification)
Integrity check	Yes — any change to the message changes the MAC	Yes — any change invalidates the signature
Authentication	Yes, but only proves the message came from someone holding the shared key	Yes, tied to the identity behind the signer's certificate
Non-repudiation	No — either party could have generated the same MAC	Yes — only the private-key holder could have produced the signature

Computational cost	Low; a single hash operation, well suited to high volume	Higher; involves modular exponentiation or elliptic-curve operations
Key distribution	Must be securely pre-shared, and re-shared if compromised	Public keys can be freely distributed via a certificate/PKI
Governing standard	RFC 2104 (HMAC)	FIPS 186-5 (Digital Signature Standard), RFC 3447 (RSA/PKCS#1)

Key Observations

- **Integrity is achieved by both mechanisms:** Both HMAC and digital signatures detect any modification to the file, so the integrity guarantee they offer is functionally equivalent.
- **HMAC cannot support non-repudiation:** HMAC only proves the message came from a party that knows the shared secret; since both data centres know that secret, HMAC cannot distinguish which of the two parties actually created it.
- **Digital signatures uniquely identify the originator:** A digital signature is bound to a specific private key that only one entity holds, so it can be presented as evidence in a settlement dispute in a way an HMAC value cannot.
- **Performance trade-off:** HMAC computation is inexpensive and scales well to high-frequency internal traffic, while signature generation and verification are markedly more CPU-intensive, particularly with RSA at large key sizes.

Critical Analysis and Recommendation

The deciding factor in this scenario is the dispute-resolution requirement, not raw integrity protection. Since HMAC and a digital signature both detect tampering equally well, the choice hinges on whether the receiving party must later prove, to a third party, exactly who produced the file. That requirement is explicitly present here (settlement disputes between two data centres), which rules out HMAC on its own.

Recommendation: the settlement files should be digitally signed using RSA-2048 or ECDSA P-256 with SHA-256, giving both integrity and non-repudiation. HMAC remains the better choice for lower-stakes, high-frequency internal traffic — for example, authenticating API calls between microservices inside a single trusted network — where speed matters more than the ability to prove authorship to an outside party.

Question 4 — Supervised vs Unsupervised Learning for Spam Detection

Scenario

An email service provider handling several million messages a day wants to build a spam-detection system. Historical mail is available with millions of messages already labelled “spam” or “not spam” by users, but new spam campaigns (novel phishing kits, freshly registered domains, image-based spam) appear daily, before any labelled examples of

them exist. The design team must weigh supervised learning against unsupervised learning for this pipeline.

Table 4.1 — Supervised and unsupervised approaches to spam detection compared

Parameter	Supervised Learning	Unsupervised Learning
Training data requirement	Requires large volumes of labelled spam/ham examples	Works on unlabelled mail, grouping it by similarity
Typical algorithms	Naive Bayes, SVM, logistic regression, random forest, gradient boosting	k-means / DBSCAN clustering, autoencoder-based anomaly detection
Detection of known spam patterns	Very high accuracy once trained on representative data	Weaker; not optimised to match a known label
Detection of novel/zero-day campaigns	Poor until retrained with newly labelled examples	Stronger; can flag messages that deviate from normal traffic as anomalies
Interpretability of results	Reasonably interpretable (feature weights, decision rules)	Harder to interpret; a cluster's meaning must be inferred
Maintenance burden	Needs continuous relabelling as spam tactics evolve	Needs periodic tuning of cluster/anomaly thresholds
False positive risk	Low, once well trained on representative data	Higher, since normal but unusual mail may resemble an anomaly

Key Observations

- **Supervised models excel at known patterns:** A supervised classifier trained on millions of labelled examples will reliably catch spam patterns it has already seen, but its accuracy degrades quickly against a spam campaign that has no prior labelled examples.
- **Unsupervised models excel at novelty:** Unsupervised methods do not need pre-existing labels, so they are better positioned to flag a brand-new phishing campaign as anomalous the first time it appears, purely because it behaves differently from ordinary mail.
- **User feedback effectively blurs the boundary between the two approaches:** Every message a user marks as spam or not-spam is itself a fresh label, so real filtering systems continually re-train supervised models on this feedback rather than treating training as a one-time event.
- **False positives are a real operational cost:** Unsupervised clustering carries a materially higher false-positive rate, which is costly in an email product because legitimate mail being misclassified directly damages user trust.

Critical Analysis and Recommendation

Neither approach on its own is adequate for a production mail system at this scale. A purely supervised system leaves a persistent blind spot against emerging campaigns, while a

purely unsupervised system produces too many false positives to be usable as the primary filter for legitimate customers.

Recommendation: deploy a hybrid pipeline in which a supervised classifier (e.g. gradient-boosted trees on message and sender features) performs the primary filtering decision, backed by an unsupervised anomaly-detection layer that flags statistically unusual traffic — new sending domains, sudden volume spikes, atypical structure — for closer scrutiny or for expedited manual labelling. This mirrors the architecture used by major mail providers and gives both high accuracy on known spam and faster adaptation to new campaigns.

Question 5 — AES vs RSA in a Secure Communication Framework

Scenario

A software-as-a-service company is designing the cryptographic core of a new client-server application that must (a) establish trust between a client and server that have never communicated before, and (b) then exchange potentially large volumes of application data with minimal latency. The design team must decide the respective roles of AES (symmetric) and RSA (asymmetric) encryption in this framework.

Table 5.1 — AES and RSA compared for confidentiality and efficiency

Parameter	AES	RSA
Algorithm type	Symmetric-key block cipher	Asymmetric-key (public-key) cryptosystem
Typical key size	128 / 192 / 256-bit key	2048 / 3072 / 4096-bit modulus
Relative speed	Very fast; suited to hardware acceleration (AES-NI)	Orders of magnitude slower for equivalent data volumes
Key distribution problem	Both parties must already share the same secret key	No pre-shared secret needed; public key can be openly distributed
Primary role in a protocol	Bulk encryption of the actual application data	Secure exchange of the AES session key, and digital signatures
Confidentiality for large data	Efficient and practical for large payloads	Impractical for large payloads; encrypted block size is limited by key size
Scalability across many users	Needs a distinct shared key per pair, or a distribution mechanism	Scales naturally — each party only needs one key pair and a certificate
Governing standard	FIPS 197 (Advanced Encryption Standard)	RFC 3447 / PKCS#1 (RSA Cryptography)

Key Observations

- **AES is efficient for bulk confidentiality:** AES-256 encrypts large payloads with negligible CPU overhead, whereas encrypting the same payload directly with RSA

would be both mathematically impractical (RSA can only encrypt data smaller than its modulus) and far slower.

- **RSA is efficient for trust establishment:** RSA lets the client and server agree on a shared AES session key without ever having communicated before, solving the key-distribution problem that AES cannot solve on its own.
- **The two algorithms solve different, complementary problems:** On its own, AES cannot bootstrap trust between two strangers, and RSA on its own is too slow to be used for ongoing bulk data transfer — each algorithm covers a gap the other leaves open.
- **Real protocols already combine both:** This is precisely the hybrid model used by TLS: RSA/ECDHE is used only briefly during the handshake, after which all subsequent traffic switches to AES.

Critical Analysis and Recommendation

Treating AES and RSA as competitors is the wrong framing for this scenario; the framework needs both, applied to different stages of the same session. RSA is well suited to the handshake, where trust must be established between two parties with no prior relationship and where the amount of data exchanged (a session key, a few kilobytes at most) is small. AES is well suited to everything that follows, where the volume of data can be large and low latency matters.

Recommendation: adopt a hybrid cryptosystem — RSA-2048 (or an ECDHE key exchange, which is faster still) for the initial handshake and session-key exchange, followed by AES-256 in GCM mode for all subsequent application data. This mirrors the design of TLS 1.3 itself and achieves both strong confidentiality and practical efficiency at scale.

References

IETF RFC 8446, The Transport Layer Security (TLS) Protocol Version 1.3, 2018.
IETF RFC 4301, Security Architecture for the Internet Protocol (IPsec), 2005.
IETF RFC 4880, OpenPGP Message Format, 2007.
IETF RFC 8551, Secure/Multipurpose Internet Mail Extensions (S/MIME) Version 4.0, 2019.
IETF RFC 2104, HMAC: Keyed-Hashing for Message Authentication, 1997.
NIST FIPS 186-5, Digital Signature Standard (DSS), 2023.
NIST FIPS 197, Advanced Encryption Standard (AES), 2001.
IETF RFC 3447, PKCS #1: RSA Cryptography Specifications, 2003.

RUBRICS FOR CALCULATION:

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
----------	---------------	---------------------	----------------------	----------------------	---------------------

Scope of Items	20%	Selects highly relevant items with clear scope and justification	Selects appropriate items with minor gaps	Selection is limited or partially relevant	Items are unclear or not relevant
Comparison Depth	25%	Provides detailed and comprehensive comparison across multiple aspects	Provides adequate comparison with some depth	Limited comparison with few aspects	Very minimal or no comparison
Use of Evidence	20%	Supports comparison with accurate data, examples, or references	Uses some supporting evidence with minor gaps	Limited or weak supporting evidence	No supporting evidence provided
Critical Thinking	20%	Demonstrates strong critical thinking with clear interpretation and reasoning	Shows reasonable interpretation with minor gaps	Basic interpretation; lacks depth	No meaningful interpretation
Clarity of Presentation	15%	Well-organized, clear, and logically structured presentation	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand